Metodología de Auditoría de Sistemas de Información

Materia: Evaluación y Auditoría de Sistemas de Información

Grupo 1

Docente: Patricia Elizabeth Romero

UMSS

Conceptos fundamentales

- **Método,** procedimiento ordenado para alcanzar un objetivo.
- **Metodología,** conjunto de métodos, técnicas y fases para realizar una auditoría.
- **Auditoría de Sistemas:** Proceso sistemático, independiente y documentado para obtener evidencia y evaluar si los controles de los sistemas de información gestionan eficazmente los riesgos, cumplen con políticas y normativas, y contribuyen a los objetivos del negocio.

Conceptos fundamentales

COBIT 2019. Marco de gobierno y gestión de Tecnologías de Información que guía cómo debe evaluarse el control interno de TI.

ISO 19011. Norma que define cómo debe planificarse, ejecutarse y documentarse una auditoría.

Metodología: El marco de trabajo estructurado que guía la auditoría. En la práctica, las metodologías se basan en estándares internacionales como **COBIT 2019** (para la gobernanza y gestión) y **ISO/IEC 27001** (para la seguridad de la información).

Metodología para realizar auditoría de sistemas computacionales

E1. Planeación

E2. Ejecución

E3. Dictamen

(Muñoz, 2002)

4 etapas:

1. Planificación
2. Trabajo de campo
3. Finalización y
4. Seguimiento.

(Amarate, 2022)

Metodología para realizar auditoría de sistemas computacionales



(Domínguez, 2021)

Metodología clásica

Metodología clásica para realizar auditoría de sistemas computacionales:

E1. Planeación

E2. Ejecución

E3. Dictamen

E1. Planeación de la auditoria de sistemas

P1. Identificar el origen de la auditoria

P2. Realizar una visita preliminar al área que será evaluada

P3. Establecer los objetivos de la auditoria

P4. Determinar los puntos que serán evaluados en la auditoria

P5. Elaborar planes, programas y presupuestos para realizar la auditoria

P6. Identificar y seleccionar los métodos, herramientas, instrumentos y procedimientos necesarios para la auditoria.

P7. Asignar los recursos y sistemas computacionales para la auditoria

Planeación de la auditoria de sistemas

P1. Identificar el origen de la auditoria

¿Por qué se realizará la auditoría?

¿Se debe hacer una visita preliminar al área de sistemas?

¿Cuál es el objetivo que se pretende alcanzar con esta auditoría?

Ejemplos:

- Por solicitud expresa de origen interno.
- Por solicitud expresa de origen externo.
- Como consecuencia de emergencias y condiciones especiales.
- Riesgos y contingencias.
- Por mandato de marcos de Gobernanza (ej. COBIT)" o "Para verificar cumplimiento con normativas (ej. GDPR, LFPDPPP en México)".

E1. Planeación de la auditoria de sistemas

P2. Visita preliminar al área que será evaluada

Contacto inicial con el personal de dicha área y que observe cómo se encuentran distribuidos los sistemas, cuántos y cuáles son los equipos que están instalados en el centro de cómputo, cuáles son sus principales características, de qué tipo son las instalaciones, cuáles son las medidas de seguridad visibles que existen.

Conocer la problemática a la cual se enfrentará, de manera simple y de carácter tentativo.

Planeación de la auditoria de sistemas

P3. Establecer los objetivos de la Auditoria

El objetivo general, es el fin global de lo que se pretende alcanzar con el desarrollo de la auditoría informática y de sistemas, en el se plantean todos los aspectos que se pretende evaluar.

Los objetivos específicos que son los fines individuales que se pretenden para el logro del objetivo general, donde se señala específicamente los sistemas, componentes o elementos concretos que deben ser evaluados.

Planeación de la auditoria de sistemas

P3. Establecer los objetivos de la Auditoria

"Evaluar la eficacia del programa de gestión de riesgos de ciberseguridad en línea con el marco NIST Cybersecurity Framework."

"Verificar el cumplimiento de los controles con la norma ISO/IEC 27001:2022."

"Auditar los controles de acceso y configuración en ambientes de computación en la nube (AWS/Azure/GCP)."

E1. Planeación de la auditoria de sistemas

P4. Determinar los aspectos que serán evaluados

Considerar aspectos específicos de los sistemas computacionales.

Por ejemplo:

La gestión administrativa del área informática y el centro de cómputo.

El cumplimiento de las funciones del personal informático y usuarios de los sistemas.

Protección de las bases de datos, datos confidenciales y accesos a las mismas.

EJEMPLOS, ASPECTOS A EVALUARSE

Gobernanza y Gestión de TI (COBIT 2019): Alineación estratégica, gestión de riesgos, gestión de recursos.

Seguridad de la Información (ISO 27001): Política de seguridad, gestión de activos, control de acceso, respuesta a incidentes, seguridad de redes.

Continuidad del Negocio y Recuperación de Desastres (BCP/DRP).

Gestión de Datos y Bases de Datos: Calidad, privacidad, gobernanza de datos.

Auditoría de Proyectos de Desarrollo (DevSecOps): Seguridad en el ciclo de vida de desarrollo de software.

Auditoría de Infraestructura y Operaciones: Física, virtual, en la nube.

E1. Planeación de la auditoria de sistemas

Los aspectos a evaluarse se pueden agrupar de la siguiente manera:

- Funciones y actividades del personal del área de sistemas
- Áreas y unidades administrativas del centro de cómputo
- Seguridad de los sistemas de información
- Información, documentación y registros de los sistemas

- Sistemas, equipos, instalaciones y componentes
- Recursos humanos del área de sistemas
- Hardware
- Software
- **Información y bases de datos**
- **Equipos, instalaciones y demás componentes**
- **Personal del área que será evaluada**

P5. Elaborar planes, programas y presupuestos

Realizar la planeación formal de la auditoría de sistemas.

Carátula.

EMPRESA: Instituto Nacional de estadística PERÍODO: del 2 al 20 de mayo del 2025

AUDITOR: José Pérez ÁREA AUDITADA: Redes de computadoras

P5. Elaborar planes, programas y presupuestos

- Definición de objetivos.
- Es la definición formal, por escrito, de los objetivos que se pretenden alcanzar con la auditoría (retomar y si es necesario reajustar los objetivos del paso 3).
- Delimitación de estrategias para el desarrollo de la auditoría
- Estrategias de acción y de actuación de los participantes en la revisión.
- Planes de auditoría. Son los planes formales de la auditoría, en los cuales se detalla cada una de las acciones.
- Para la evaluación; estos planes serán presentados de acuerdo a las preferencias y necesidades específicas de auditoría de la empresa.

E1. Planeación de la auditoria de sistemas

P5. Elaborar planes, programas y presupuestos

PLAN DE AUDITORÍA DE SISTEMA

ACTIVIDAD			SEMANAS							
No.	**Nombre**	**responsable**	**1**	**2**	**3**	**4**	**5**	**6**	**7**	**8**
1	Elaborar plan de auditoría	J. Dpto. asignado								
2	Aprobar plan de auditoría	Director								
3	Prepara instrumentos de remisión	Resp. Auditor								
4	Iniciar preparativos	Aud. Senior								
5	Cobrar viáticos y pasajes	Aud. Asignados								
6	Iniciar viaje	Aud. Asignados								
7	Iniciar auditoría	Aud. Asignados								
8	Auditar gestión informática	Aud. Sr. 1								
9	Auditar Bases de datos	Aud. Sr. 2								

E1. Planeación de la auditoria de sistemas

P6. Identificar y seleccionar los métodos, herramientas, Instrumentos y procedimientos necesarios para la auditoria.

a) Establecer la guía de ponderación de cada uno de los puntos que se debe evaluar.
b) Elaborar una guía de la auditoria.
c) Elaborar el documento formal de la guía de auditoría.
d) Determinar las herramientas, métodos y procedimientos para la auditoria de sistemas.
e) Diseñar los sistemas, programas y métodos de pruebas para la auditoria.

E1. Planeación de la auditoria de sistemas

P7. Asignar los recursos y sistemas computacionales para la auditoría

- Recursos humanos para la realización de la auditoría.
- Recursos informáticos y tecnológicos para la realización A.S.I.
- Recursos materiales y de consumo.
- Otros (viáticos, pasajes, etc.).

E2. Ejecución de la auditoria de sistemas

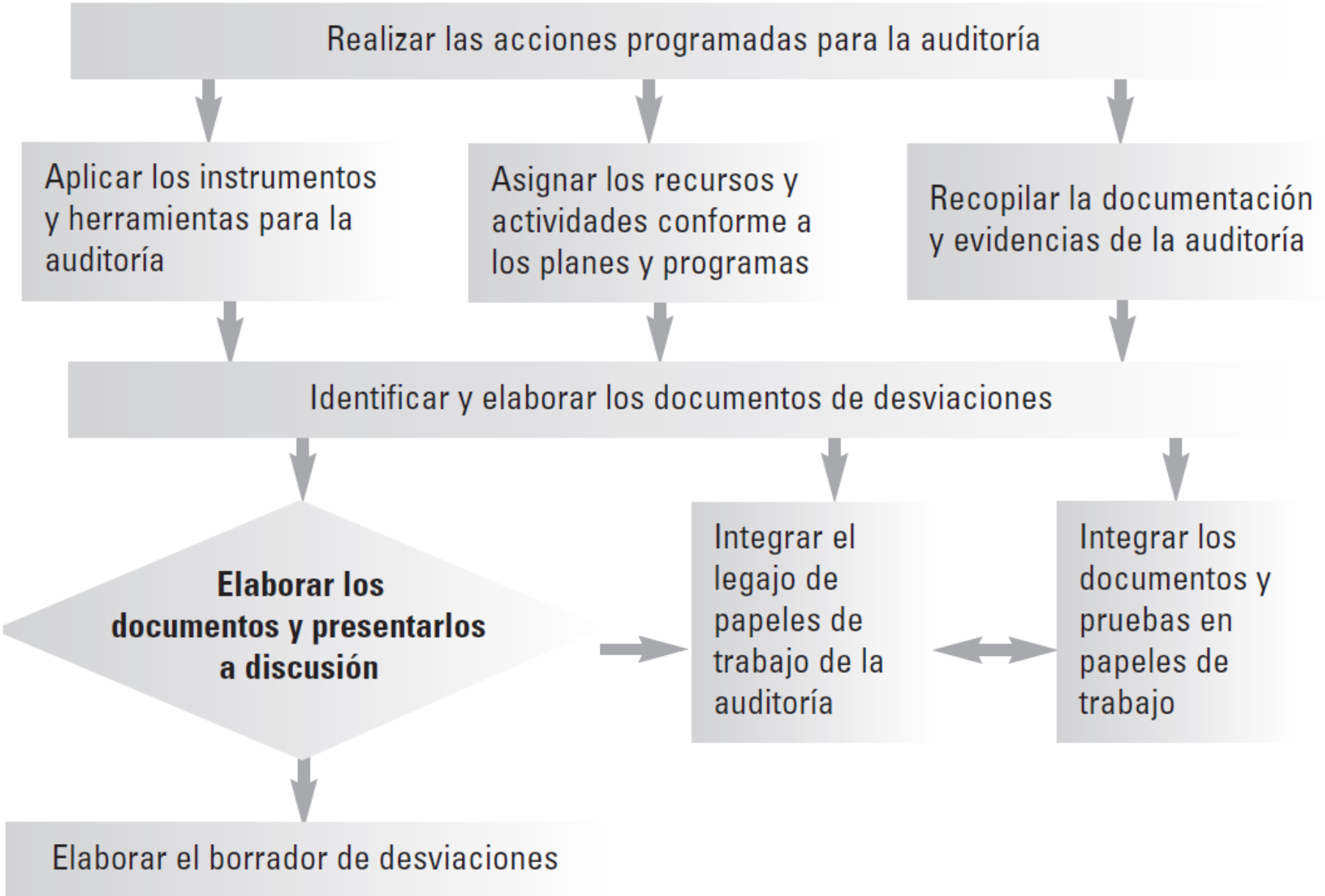
E1. Realizar las acciones programadas para la auditoria.

E2. Aplicar los instrumentos y herramientas para la auditoria.

E3. Identificar y elaborar los documentos de oportunidades de mejoramiento encontradas.

E4. Elaborar el dictamen preliminar y presentarlo a discusión.

E5. Integrar el legajo de papeles de trabajo de la auditoria.


Realizar las acciones programadas para la auditoría
Aplicar los instrumentos y herramientas para la auditoría
Asignar los recursos y actividades conforme a los planes y programas
Recopilar la documentación y evidencias de la auditoría
Identificar y elaborar los documentos de desviaciones
Elaborar los documentos y presentarlos a discusión
Integrar el legajo de papeles de trabajo de la auditoría
Integrar los documentos y pruebas en papeles de trabajo
Elaborar el borrador de desviaciones

Dictamen de la auditoria de sistemas

D1. Analizar la información y elaborar un informe de situaciones detectadas.

- Analizar los papeles de trabajo.
- Señalar las situaciones encontradas.
- Realizar las modificaciones necesarias (al informe).
- Elaborar un documento de situaciones relevantes.

el fin de una auditoría de sistemas computacionales no es encontrar culpables, sino ayudar a corregir las desviaciones encontradas en la operación normal de dichos sistemas

Una vez que ha detectado las desviaciones, es obligación ineludible del auditor comentarlas en forma directa y abierta con los responsables de la operación, a fin de que las conozcan, acepten, aclaren, complementen y/o las modifiquen con detalles y pruebas.

Dictamen de la auditoria de sistemas

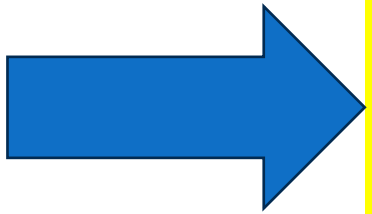
D2. Elaborar el dictamen final.

- Analizar la información y elaborar un documento de desviaciones detectadas.
- Elaborar el informe y el dictamen formales.
- Comentar con los auditados, comentar con los directivos.
- Realizar las modificaciones necesarias

Dictamen de la auditoria de sistemas

D3. Dictamen de la auditoria de sistemas

- La carta de presentación
- El dictamen de la auditoría
- El informe de situaciones relevantes
- Anexos y cuadros adicionales



"Nótese que todas las metodologías convergen en las fases de Planificación, Ejecución e Informe. La fase de **Seguimiento** es crítica para asegurar que las mejoras se implementen."

Metodología Auditoría de Sistemas de Información

Propuesta metodológica que integra elementos de distintos marcos y normas:

- ISO 19011: proporciona directrices para auditar sistemas de gestión, incluyendo la planificación, ejecución, presentación de resultados y seguimiento.
- COBIT: es un marco de gobierno y gestión de la información y la tecnología empresarial. Ayuda a establecer criterios, objetivos de control y mecanismos de evaluación.
- Ciclo PDCA (Plan–Do–Check–Act): es un enfoque de mejora continua, no una metodología de auditoría propiamente dicha.

Metodología de A.S.I.

1. PLANIFICACIÓN

Definición de objetivos, alcance, criterios, riesgos, recursos y programa de auditoría.

ISO 19011 / COBIT MEA04

2. EJECUCIÓN (TRABAJO DE CAMPO)

Entrevistas, revisión documental, pruebas de controles, recopilación y evaluación de evidencias.

ISO 19011 / COBIT MEA02–MEA04

3. INFORME DE AUDITORÍA

Presentación de hallazgos, evidencias, conclusiones y recomendaciones.

ISO 19011 / COBIT MEA04

4. SEGUIMIENTO Y MEJORA

Verificación de acciones correctivas y evaluación de su eficacia.

ISO 19011 / COBIT MEA04

BIBLIOGRAFÍA

Amarate David J. (2022). *Auditoría de Sistemas de Información.* Edición Kindle.

Domínguez Jorge (2021). *Fundamentos de Auditoría Informática.* IEASS

Muñoz R. Carlos (2002). *Auditoría de Sistemas Computacionales.* Ed. Pearson

Ed. Taylor & Francis Group

Otero Angel (2019). *Information Technology Control and Audit.* CRC Press

ISO/IEC 19011:2026. Guidelines for auditing management systems. https://www.iso.org/standard/19011?utm_source=chatgpt.com

ISO/IEC 27001:2022Information security, cybersecurity and privacy protection — Information security management systems — Requirements

COBIT 2019 (ISACA)

Actividades en la clase, en grupos de 3

Caso de Sistema de incripciones universitarias. Durante las inscripciones, algunos estudiantes reportan que sus materias desaparecen del sistema. Además, existen denuncias de que ciertas personas pueden modificar inscripciones sin autorización.

1.¿Cuál sería el objetivo de la auditoría?

2.¿Qué aspectos del sistema deberían evaluarse?

3.¿Qué áreas o personas deberían participar?

Pasos P3 y P4 de la metodología clásica.

¿En qué fase o etapa estamos?

1. El auditor entrevista al administrador de la base de datos.
2. Se determina qué sistemas y controles serán evaluados.
3. Se redactan las conclusiones y recomendaciones.
4. Se comprueba que se corrigieron los accesos indebidos.
5. Se seleccionan los instrumentos y pruebas que se utilizarán.

Caso: Auditoría a una aplicación bancaria de pagos QR

Una entidad bancaria ha recibido reclamos de clientes sobre su aplicación móvil:

- Algunos pagos mediante QR se debitan dos veces.
- En ocasiones, el dinero se descuenta, pero el comercio no recibe la confirmación.
- Algunos usuarios afirman que la aplicación permite ingresar con mecanismos de autenticación poco seguros.
- Los clientes se quejan de que sus reclamos tardan demasiado en resolverse.

La gerencia solicita una auditoría para evaluar los controles internos relacionados con los pagos QR.

Aplicar los pasos 1, 3 y 4 de la metodología clásica.